

Ledra セキュリティ ホワイトペーパー

暗号化・アクセス制御・バックアップ・脆弱性対応・改ざん防止。記録の信頼を仕組みで守るための、技術担当者・情報セキュリティ担当者向け一次資料です。

本資料の想定読者

- ・情報システム部門・セキュリティ責任者
- ・導入審査・監査対応を行う担当者
- ・保険会社・代理店の技術対応窓口

目次

00. セキュリティ3層モデル

1. 暗号化 — 通信・保存・ペイロードの3層で、データを守ります。
 2. アクセス制御 — 役割・テナント・セッション境界を、DB レベルで強制します。
 3. バックアップ・可用性 — 喪失と停止に備え、復旧を既定の運用に。
 4. 脆弱性対応 — 見つけ次第、直す。その運用を仕組みで。
 5. 改ざん防止 — 『記録を、業界の共通言語にする』ための根拠。
- ### 06. Polygon anchoring フロー
07. データライフサイクル（保管・削除・テナント境界）
 08. 認証取得状況・インシデント対応・窓口

記録の信頼を、仕組みで守る。

セキュリティ3層モデル

通信・保存・ペイロードの3層で、独立に働く防御を重ねています。どれか1層が突破されても、他の層で被害を局所化する設計です。

層1: 通信 (Transport)

TLS 1.2+ による経路全体の暗号化。HSTS により HTTPS ダウングレードを防止。内部サービス間も mTLS 相当の境界で分離。

層2: 保存 (At-Rest)

Postgres は AES-256 によるディスク暗号化。オブジェクトストレージは転送時・保管時ともに暗号化。バックアップも同様の暗号化を継承。

層3: ペイロード (Data-Level)

DB 内部の機微データにアプリ層のハッシュ化・pepper 適用を追加。DB 管理者を含む全アクセス経路でも生値が復元できない形に。

独立性の担保

- 各層の鍵は異なる KMS/Vault で管理、ローテーション周期も独立。
- ペイロード層のソルト/ペッパーはアプリケーションシークレットとしてのみ管理。
- 監査証跡は各層で独立に採取し、時刻同期のみ共通化。

1. 暗号化

通信・保存・ペイロードの3層で、データを守ります。

通信の暗号化 (TLS 1.2+)

アプリとAPIの全トラフィックを TLS で暗号化。Vercel の HTTPS 終端を使用し、HSTS を有効化しています。

保存データの暗号化

Supabase Postgres はディスク暗号化 (AES-256) および自動鍵ローテーションを実装。 - オブジェクトストレージも転送時・保管時ともに暗号化。

機微データのペッピング

顧客認証に用いる電話番号末尾4桁などは、アプリレイヤで pepper 付きハッシュ化してから保存。DB 流出時にも生値が復元できない形に。

Polygon anchoring

施工写真の SHA-256 ハッシュを Polygon ブロックチェーンに刻印。仮に DB 側の写真が差し替えられても、チェーン上のアンカーと突き合わせて不整合を即検知できます。

2. アクセス制御

役割・テナント・セッション境界を、DB レベルで強制します。

Row Level Security (RLS)

Supabase の RLS を全テーブルで有効化。テナント・役割・所有者の3軸で、SQL レイヤでアクセス可能な行を制限。

役割ベースアクセス制御 (RBAC)

Owner / Admin / Staff / Viewer の4段階に加え、代理店・保険会社・顧客の独立したロール。必要最小限の権限のみを付与。

多要素認証 (MFA) 対応

ポータルユーザー向けに、Supabase Auth の TOTP/SMS MFA を設定可能。

セッション管理

顧客ポータルは専用のセッション有効期限 (デフォルト24時間)。署名付き URL は1回限りのトークンで発行。

レート制限

Upstash Redis による分散レートリミット。ログイン・問合せ・API ごとに上限を設定し、ブルートフォース・スクレイピングを抑制。

3. バックアップ・可用性

喪失と停止に備え、復旧を既定の運用に。

日次自動バックアップ

Supabase Postgres の日次自動バックアップ + ポイントインタイムリカバリ。誤削除から任意時点への復旧を可能にします。

地理冗長配置

アプリケーションは Vercel の東京リージョンを主、グローバルエッジキャッシュを併用。大規模障害時も読み取りは継続可能。

監視・アラート

Sentry による例外トラッキング、Vercel Analytics / Speed Insights による性能監視。Cron ジョブの失敗検知も自動化。

4. 脆弱性対応

見つけ次第、直す。その運用を仕組みで。

依存ライブラリの継続監視

GitHub Dependabot により CVE を日次監視。Critical は即時、High は 72 時間以内に対応する運用ルール。

CI でのセキュリティチェック

ESLint の security ルール、Secret scanning、型チェックをプルリクエストごとに実行。マージ前に既知の問題を遮断。

ログ監査

認証・証明書発行・無効化・顧客情報閲覧など、重要操作の監査ログを保存。異常操作の追跡が可能。

脆弱性報告窓口

security@ledra.co.jp にてセキュリティ関連のご報告を受け付けます。ご連絡から3営業日以内に初期対応いたします。

5. 改ざん防止

『記録を、業界の共通言語にする』ための根拠。

証明書編集履歴

証明書への編集操作は差分付きで編集履歴に保存。『誰が、いつ、何を変えたか』を後から確認できます。

C2PA 画像署名

施工写真を証明書と紐付ける際、C2PA 規格で署名付きのコンテンツクレデンシャルを埋め込み。SNS 等で再配布されても出自を追跡可能。

Polygon anchoring

発行時に証明書コンテンツのハッシュを Polygon に刻印。後からデータが書き換えられても、チェーン上のアンカーとの差分で検知できます。

デジタル署名

証明書 PDF には Ledra の署名鍵で署名を付与。発行元の同一性を第三者が検証可能。

Polygon anchoring フロー

証明書発行時のハッシュ刻印から、第三者による独立検証までの一連の流れです。

発行フロー（書き込み側）

1. 証明書コンテンツ（写真 / 施工内容 / 施工者 / 日時）を正準化し、SHA-256 で確定値を算出。
2. ハッシュを Ledra の anchoring キューに投入。バッチで Polygon PoS の anchoring コントラクトに送信。
3. トランザクションハッシュと block number を証明書レコードに記録。UI の「検証済」バッジが点灯。

検証フロー（読み取り側）

1. 任意の第三者が証明書コンテンツと記録済みトランザクションを取得。
2. 手元でコンテンツを同じ正準化手順で SHA-256 計算。
3. Polygon 上の anchoring コントラクトに読み出し、ハッシュ一致を確認。

設計上の要点

- Ledra 側 DB が改変されても、Polygon 上の記録との比較で検知可能。
- 写真そのものは C2PA 署名で独立検証。チェーン上にはハッシュのみ記録。
- ガス代高騰時に備え、バッチ Merkle 化で個別トランザクション数を抑制。

データライフサイクル

テナントデータの取得から削除までの流れ・保管期間・権限境界を明示します。

テナント境界

- 全ての業務テーブルに `tenant_id` を必須カラムとして設定。
- RLS ポリシーにより、SQL クエリは自動的に所属テナントのみに絞り込み。
- バックアップ単位もテナント識別子を残し、データエクスポート時は `tenant_id` フィルタを強制。

保管期間

データ種別	保管期間
証明書・施工写真	契約期間中 + 契約終了後 3 年
顧客個人情報（氏名・連絡先）	契約期間中 + 契約終了後 1 年
監査ログ	最低 5 年
自動バックアップ	最大 30 日（PITR）

データ削除・エクスポート

- 退会時はテナント単位で論理削除 30 日後に物理削除。
- 個別の顧客情報削除依頼は、本人確認後 30 日以内に対応。
- 全データの CSV / JSON エクスポートは、Admin 権限者がいつでも取得可能。

認証・インシデント対応・お問い合わせ

認証取得状況

ISMS (ISO/IEC 27001)

取得準備中。取得時期は本ホワイトペーパーおよび /security ページにて告知します。

プライバシーマーク

取得準備中。社内ポリシー整備・教育実施を先行して進めています。

インシデント対応フロー

1. 検知: Sentry / 監査ログ / 外部報告のいずれかでトリアージ開始。
2. 初期対応: 24 時間以内に影響範囲を確定、必要なら緊急措置（当該機能停止・鍵ローテーション）。
3. 連絡: 影響テナントには個別連絡、重大事象は公開インシデントレポートを発行。
4. 恒久対応: 根本原因分析（RCA）を実施、再発防止策をチェンジログに記録。

お問い合わせ

セキュリティ 報告: security@ledra.co.jp

技術問合せ: info@ledra.co.jp

Web: <https://ledra.co.jp/security>

本資料は公開時点の情報で作成しています。認証取得の進捗・技術仕様の更新は /security ページおよび最新版-ホワイトペーパーに反映します。